STRIDE ISP 1.0 – Information Security Program Policy

Version [2.0]

Stride Corporate Directive:

This document contains a Stride Corporate Directive; all business units must comply per the authority vested in the signatories provided herein.

Purpose:

Stride recognizes the critical nature of information security and the need to demonstrate administrative, technical, and physical safeguards to assure the confidentiality, integrity, and availability of essential assets that store or process information.

This policy sets high-level requirements for enhanced IT policy, controls, standards, and procedures for managing data and information entrusted to Stride and ensures an IT environment in which information may be created, used, stored, and disposed of in a manner that promotes confidentiality, integrity, and availability of that information.

Scope and Applicability

This policy applies to all Stride-owned technology and business operations.

All workforce members and their respective facilities supporting Stride business operations, technology, or both, wherever Stride data is stored or processed, including any third party contracted by Stride to handle, process, transmit, store, or dispose of Stride data are subject to the requirements of this document.

All data, systems, activities, and assets owned, leased, controlled, or used by Stride, its agents, contractors, or other business partners on behalf of Stride are within the scope of the requirements of this document.

The requirements outlined in this document apply where technically feasible and commercially reasonable, as determined by executive management. Any exceptions to these standards must be requested using the approved workflow and remain documented until compliance has been achieved. Exceptions are only granted temporarily for periods of up to one calendar year.

Definitions

All definitions are located within Stride - ISP 1.2 – IT Policy Definitions.

Any inquiries regarding terminology or clarity may be directed to Stride's Information Security Team for assistance.

Publication Owners

Johnny Burns – Point of Contact, Content Coordinator & Author

Jen Havenner – Business Owner

Mark Williams – Executive Sponsor

Document Control

This document may contain proprietary, confidential, or sensitive information owned wholly by Stride Inc. Any distribution of the information contained within this document, in whole or in part, outside of Stride or its subsidiary entities requires the approval of the Executive Sponsor.

This document will be reviewed at least annually and re-issued when revisions are necessary. Any changes introduced in the most recent version are itemized below. Obsolete copies should be destroyed or archived upon the release of the newest version.

Implementation and Compliance

All business units are required to comply with any changes applied to the most recent version of this publication within 90 days from the date of publication.

Change History

Version	Date of Change	Summary of Change(s)
1.0	6/15/2022	Initial Release and Publication
1.1	12/01/2022	- Added Change History - Updated and/or redacted language for clarity where necessary
1.2	03/17/2023	- Updated approvals section
1.3	01/01/2024	- Updated Purpose/Scope/Document Control/Implementation and Compliance - Changed formatting to new standard - Changed document images
2.0	01/31/2025	- Updated Policy Title - Updated Policy to match NIST 2.0 Release Changes - Updated Publication Owners
2.0	02/24/2025	- Approved Mark Williams - CISO
2.0	03/06/2025	- Published

INFORMATION SECURITY PROGRAM POLICY

The organization develops, disseminates, periodically reviews, and updates a documented information security program that addresses purpose, scope, roles, and responsibilities. This policy provides a formal directive for the implementation of controls, standards, and procedures to meet compliance objectives defined by the NIST Cybersecurity Framework (NIST CSF) and adopted by Executive Leadership at Stride.

GOVERN (GV) The organization's cybersecurity risk management strategy, expectations, and policy are established, communicated, and monitored	
Organizational Context (GV.OC): The circumstances — mission, stakeholder expectations, dependencies, and legal, regulatory, and contractual requirements — surrounding the organization's cybersecurity risk management decisions are understood.	
GV.OC-01	The organizational mission is understood and informs cybersecurity risk management
GV.OC-02	Internal and external stakeholders are understood, and their needs and expectations regarding cybersecurity risk management are understood and considered
GV.OC-03	Legal, regulatory, and contractual requirements regarding cybersecurity — including privacy and civil liberties obligations — are understood and managed
GV.OC-04	Critical objectives, capabilities, and services that external stakeholders depend on or expect from the organization are understood and communicated
GV.OC-05	Outcomes, capabilities, and services that the organization depends on are understood and communicated
Risk Management Strategy (GV.RM): The organization's priorities, constraints, risk tolerance and appetite statements, and assumptions are established, communicated, and used to support operational risk decisions	
GV.RM-01	Risk management objectives are established and agreed to by organizational stakeholders
GV.RM-02	Risk appetite and risk tolerance statements are established, communicated, and maintained
GV.RM-03	Cybersecurity risk management activities and outcomes are included in enterprise risk management processes
GV.RM-04	Strategic direction that describes appropriate risk response options is established and communicated
GV.RM-05	Lines of communication across the organization are established for cybersecurity risks, including risks from suppliers and other third parties
GV.RM-06	A standardized method for calculating, documenting, categorizing, and prioritizing cybersecurity risks is established and communicated

GV.RM-07	Strategic opportunities (i.e., positive risks) are characterized and are included in organizational cybersecurity risk discussions
Roles, Responsibilities, and Authorities (GV.RR): Cybersecurity roles, responsibilities, and authorities to foster accountability, performance assessment, and continuous improvement are established and communicated	
GV.RR-01	Organizational leadership is responsible and accountable for cybersecurity risk and fosters a culture that is risk-aware, ethical, and continually improving
GV.RR-02	Roles, responsibilities, and authorities related to cybersecurity risk management are established, communicated, understood, and enforced
GV.RR-03	Adequate resources are allocated commensurate with the cybersecurity risk strategy, roles, responsibilities, and policies
GV.RR-04	Cybersecurity is included in human resources practices
Policy (GV.PO): Organizational cybersecurity policy is established, communicated, and enforced	
GV.PO-01	Policy for managing cybersecurity risks is established based on organizational context, cybersecurity strategy, and priorities and is communicated and enforced
GV.PO-02	Policy for managing cybersecurity risks is reviewed, updated, communicated, and enforced to reflect changes in requirements, threats, technology, and organizational mission
Oversight (GV.OV): Results of organization-wide cybersecurity risk management activities and performance are used to inform, improve, and adjust the risk management strategy	
GV.OV-01	Cybersecurity risk management strategy outcomes are reviewed to inform and adjust strategy and direction
GV.OV-02	The cybersecurity risk management strategy is reviewed and adjusted to ensure coverage of organizational requirements and risks
GV.OV-03	Organizational cybersecurity risk management performance is evaluated and reviewed for adjustments needed
Cybersecurity Supply Chain Risk Management (GV.SC): Cyber supply chain risk management processes are identified, established, managed, monitored, and improved by organizational stakeholders	
GV.SC-01	A cybersecurity supply chain risk management program, strategy, objectives, policies, and processes are established and agreed to by organizational stakeholders
GV.SC-02	Cybersecurity roles and responsibilities for suppliers, customers, and partners are established, communicated, and coordinated internally and externally
GV.SC-03	Cybersecurity supply chain risk management is integrated into cybersecurity and enterprise risk management, risk assessment, and improvement processes
GV.SC-04	Suppliers are known and prioritized by criticality

GV.SC-05	Requirements to address cybersecurity risks in supply chains are established, prioritized, and integrated into contracts and other types of agreements with suppliers and other relevant third parties
GV.SC-06	Planning and due diligence are performed to reduce risks before entering into formal supplier or other third-party relationships
GV.SC-07	The risks posed by a supplier, their products and services, and other third parties are understood, recorded, prioritized, assessed, responded to, and monitored over the course of the relationship
GV.SC-08	Relevant suppliers and other third parties are included in incident planning, response, and recovery activities
GV.SC-09	Supply chain security practices are integrated into cybersecurity and enterprise risk management programs, and their performance is monitored throughout the technology product and service life cycle
GV.SC-10	Cybersecurity supply chain risk management plans include provisions for activities that occur after the conclusion of a partnership or service agreement

IDENTIFY (ID) The organization's current cybersecurity risks are understood	
Asset Management (ID.AM): Assets (e.g., data, hardware, software, systems, facilities, services, people) that enable the organization to achieve business purposes are identified and managed consistent with their relative importance to organizational objectives and the organization's risk strategy	
ID.AM-01	Inventories of hardware managed by the organization are maintained
ID.AM-02	Inventories of software, services, and systems managed by the organization are maintained
ID.AM-03	Representations of the organization's authorized network communication and internal and external network data flows are maintained
ID.AM-04	Inventories of services provided by suppliers are maintained
ID.AM-05	Assets are prioritized based on classification, criticality, resources, and impact on the mission
ID.AM-07	Inventories of data and corresponding metadata for designated data types are maintained
ID.AM-08	Systems, hardware, software, services, and data are managed throughout their life cycles
Risk Assessment (ID.RA): The cybersecurity risk to the organization, assets, and individuals is understood by the organization	
ID.RA-01	Vulnerabilities in assets are identified, validated, and recorded
ID.RA-02	Cyber threat intelligence is received from information sharing forums and sources

ID.RA-03	Internal and external threats to the organization are identified and recorded
ID.RA-04	Potential impacts and likelihoods of threats exploiting vulnerabilities are identified and recorded
ID.RA-05	Threats, vulnerabilities, likelihoods, and impacts are used to understand inherent risk and inform risk response prioritization
ID.RA-06	Risk responses are chosen, prioritized, planned, tracked, and communicated
ID.RA-07	Changes and exceptions are managed, assessed for risk impact, recorded, and tracked
ID.RA-08	Processes for receiving, analyzing, and responding to vulnerability disclosures are established
ID.RA-09	The authenticity and integrity of hardware and software are assessed prior to acquisition and use
ID.RA-10	Critical suppliers are assessed prior to acquisition
Improvement (ID.IM): Improvements to organizational cybersecurity risk management processes, procedures and activities are identified across all CSF Functions	
ID.IM-01	Improvements are identified from evaluations
ID.IM-02	Improvements are identified from security tests and exercises, including those done in coordination with suppliers and relevant third parties
ID.IM-03	Improvements are identified from execution of operational processes, procedures, and activities
ID.IM-04	Incident response plans and other cybersecurity plans that affect operations are established, communicated, maintained, and improved

PROTECT (PR) Safeguards to manage the organization's cybersecurity risk are used	
Identity Management, Authentication, and Access Control (PR.AA): Access to physical and logical assets is limited to authorized users, services, and hardware and managed commensurate with the assessed risk of unauthorized access	
PR.AA-01	Identities and credentials for authorized users, services, and hardware are managed by the organization
PR.AA-02	Identities are proofed and bound to credentials based on the context of interactions
PR.AA-03	Users, services, and hardware are authenticated
PR.AA-04	Identity assertions are protected, conveyed, and verified
PR.AA-05	Access permissions, entitlements, and authorizations are defined in a policy, managed, enforced, and reviewed, and incorporate the principles of least privilege and separation of duties
PR.AA-06	Physical access to assets is managed, monitored, and enforced commensurate with risk
Awareness and Training (PR.AT): The organization's personnel are provided with cybersecurity awareness and training so that they can perform their cybersecurity-related tasks	

PR.AT-01	Personnel are provided with awareness and training so that they possess the knowledge and skills to perform general tasks with cybersecurity risks in mind
PR.AT-02	Individuals in specialized roles are provided with awareness and training so that they possess the knowledge and skills to perform relevant tasks with cybersecurity risks in mind
Data Security (PR.DS): Data are managed consistent with the organization's risk strategy to protect the confidentiality, integrity, and availability of information	
PR.DS-01	The confidentiality, integrity, and availability of data-at-rest are protected
PR.DS-02	The confidentiality, integrity, and availability of data-in-transit are protected
PR.DS-10	The confidentiality, integrity, and availability of data-in-use are protected
PR.DS-11	Backups of data are created, protected, maintained, and tested
Platform Security (PR.PS): The hardware, software (e.g., firmware, operating systems, applications), and services of physical and virtual platforms are managed consistent with the organization's risk strategy to protect their confidentiality, integrity, and availability	
PR.PS-01	Configuration management practices are established and applied
PR.PS-02	Software is maintained, replaced, and removed commensurate with risk
PR.PS-03	Hardware is maintained, replaced, and removed commensurate with risk
PR.PS-04	Log records are generated and made available for continuous monitoring
PR.PS-05	Installation and execution of unauthorized software are prevented
PR.PS-06	Secure software development practices are integrated, and their performance is monitored throughout the software development life cycle
Technology Infrastructure Resilience (PR.IR): Security architectures are managed with the organization's risk strategy to protect asset confidentiality, integrity, and availability, and organizational resilience	
PR.IR-01	Networks and environments are protected from unauthorized logical access and usage
PR.IR-02	The organization's technology assets are protected from environmental threats
PR.IR-03	Mechanisms are implemented to achieve resilience requirements in normal and adverse situations
PR.IR-04	Adequate resource capacity to ensure availability is maintained

DETECT (DE) Possible cybersecurity attacks and compromises are found and analyzed.	
Continuous Monitoring (DE.CM): Assets are monitored to find anomalies, indicators of compromise, and other potentially adverse events	
DE.CM-01	Networks and network services are monitored to find potentially adverse events
DE.CM-02	The physical environment is monitored to find potentially adverse events

DE.CM-03	Personnel activity and technology usage are monitored to find potentially adverse events
DE.CM-06	External service provider activities and services are monitored to find potentially adverse events
Adverse Event Analysis (DE.AE): Anomalies, indicators of compromise, and other potentially adverse events are analyzed to characterize the events and detect cybersecurity incidents	
DE.AE-02	Potentially adverse events are analyzed to better understand associated activities
DE.AE-03	Information is correlated from multiple sources
DE.AE-04	The estimated impact and scope of adverse events are understood
DE.AE-06	Information on adverse events is provided to authorized staff and tools
DE.AE-07	Cyber threat intelligence and other contextual information are integrated into the analysis
DE.AE-08	Incidents are declared when adverse events meet the defined incident criteria

RESPOND (RS) Actions regarding a detected cybersecurity incident are taken.	
Incident Management (RS.MA): Responses to detected cybersecurity incidents are managed	
RS.MA-01	The incident response plan is executed in coordination with relevant third parties once an incident is declared
RS.MA-02	Incident reports are triaged and validated
RS.MA-03	Incidents are categorized and prioritized
RS.MA-04	Incidents are escalated or elevated as needed
RS.MA-05	The criteria for initiating incident recovery are applied
Incident Analysis (RS.AN): Investigations are conducted to ensure effective response and support forensics and recovery activities	
RS.AN-03	Analysis is performed to establish what has taken place during an incident and the root cause of the incident
RS.AN-06	Actions performed during an investigation are recorded, and the records' integrity and provenance are preserved
RS.AN-07	Incident data and metadata are collected, and their integrity and provenance are preserved
RS.AN-08	An incident's magnitude is estimated and validated

Incident Response Reporting and Communication (RS.CO): Response activities are coordinated with internal and external stakeholders as required by laws, regulations, or policies	
RS.CO-02	Internal and external stakeholders are notified of incidents
RS.CO-03	Information is shared with designated internal and external stakeholders
Incident Mitigation (RS.MI): Activities are performed to prevent expansion of an event and mitigate its effects	
RS.MI-01	Incidents are contained
RS.MI-02	Incidents are eradicated

RECOVER (RC) Assets and operations affected by a cybersecurity incident are restored.	
Incident Recovery Plan Execution (RC.RP): Restoration activities are performed to ensure operational availability of systems and services affected by cybersecurity incidents.	
RC.RP-01	The recovery portion of the incident response plan is executed once initiated from the incident response process
RC.RP-02	Recovery actions are selected, scoped, prioritized, and performed
RC.RP-03	The integrity of backups and other restoration assets is verified before using them for restoration
RC.RP-04	Critical mission functions and cybersecurity risk management are considered to establish post-incident operational norms
RC.RP-05	The integrity of restored assets is verified, systems and services are restored, and normal operating status is confirmed
RC.RP-06	The end of incident recovery is declared based on criteria, and incident-related documentation is completed
Incident Recovery Communication (RC.CO): Restoration activities are coordinated with internal and external parties	
RC.CO-03	Recovery activities and progress in restoring operational capabilities are communicated to designated internal and external stakeholders
RC.CO-04	Public updates on incident recovery are shared using approved methods and messaging